Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

List of teammates:

S.no	Name	Collage	Mail ID
01	SIVA GURU.A	Shri Nehru Maha Vidyalaya College of Arts & Science	sivaguru.a1@gmail.com
02	RAJASEKAR.S	Shri Nehru Maha Vidyalaya College of Arts & Science	rajasekar032006@gmail.com
03	PRANAV.S	Shri Nehru Maha Vidyalaya College of Arts & Science	pranavsivadas75@gmail.com
04	RAMYA.M	Shri Nehru Maha Vidyalaya College of Arts & Science	m.kezia2006@gmail.com
05	NAVEEN KUMAR.S	Shri Nehru Maha Vidyalaya College of Arts & Science	naveen8883205988@gmail.com

Introduction

Modern organizations rely heavily on cloud applications and remote access technologies. As employees, students, and administrators work from different locations, securing access to sensitive resources has become a critical challenge. Traditional security models that depend on network-based trust and VPN access often create security risks because users are granted broad network access after authentication.

This project focuses on integrating the cloud security platform Zscaler with enterprise Identity Providers such as Microsoft Entra ID, Okta, and Active Directory. The integration enables centralized identity management where authentication and authorization decisions are based on verified user identities rather than network location.

By connecting Zscaler with these identity providers, organizations can enforce secure access policies, implement Single Sign-On (SSO), and ensure that only authenticated users can access internal applications and internet services. This approach simplifies user authentication while improving security by eliminating multiple login credentials and reducing administrative overhead.

The integration also supports advanced security mechanisms such as Multi-Factor Authentication (MFA), automated user provisioning, and role-based access control. These capabilities help organizations create a secure and efficient authentication framework that supports modern work environments.

Ultimately, the project demonstrates how identity-based security models can enhance network protection while improving the user experience for employees and administrators.

Abstract:

With the increasing adoption of cloud computing and remote work environments, traditional security approaches are no longer sufficient to protect organizational resources. Modern security strategies emphasize identity-based access control, where user identity becomes the primary factor for authentication and authorization.

This project explores the integration of Zscaler security services with enterprise Identity Providers including Microsoft Entra ID, Okta, and on-premises Active Directory. The goal is to establish a unified authentication mechanism that allows users to securely access applications and network services through a single trusted identity platform.

The integration utilizes modern authentication protocols such as Security Assertion Markup Language (SAML), OpenID Connect (OIDC), and System for Cross-domain Identity Management (SCIM). These protocols enable secure communication between the identity provider and the Zscaler platform, allowing organizations to authenticate users through centralized directories.

By implementing Single Sign-On (SSO), users can access multiple services using a single login, reducing password fatigue and improving productivity. Additionally, Multi-Factor Authentication (MFA) strengthens security by requiring additional verification methods during login attempts.

This project highlights the advantages of identity-driven security architectures and demonstrates how integrating cloud security platforms with identity providers can create a scalable and secure access control system suitable for modern enterprises.

Use Case Scenarios:

Scenario 1: Remote Faculty Access To Research Data

A company employee working from home needs access to internal company applications such as file servers or project management tools. Instead of connecting through a traditional VPN, the user authenticates using the organization's identity provider. Once authenticated, Zscaler verifies the user identity and grants secure access only to authorized applications.

Output:

- Identity verification through Identity Provider
- Secure application access
- Multi-factor authentication enforcement
- Restricted network visibility

Scenario 2: Student Access to Library Resources

Students often require remote access to digital libraries, academic portals, and internal learning platforms. Through integration with identity providers such as Microsoft Entra ID, students can log in using their university credentials. Zscaler ensures that only authorized students gain access to licensed academic resources.

Output:

- Verified student identity
- Controlled access to learning portals
- Secure remote connectivity
- Simplified login experience

Scenario 3: HR Administrator Access to Payroll System

In this scenario, the HR administrator logs into the organization's system using an identity provider such as Microsoft Entra ID, Okta, or Active Directory. After successful authentication, the access request is verified by Zscaler, which checks whether the user has the appropriate role and permissions to access the payroll application.

By integrating identity providers with Zscaler, organizations can ensure secure and controlled access to payroll systems while protecting sensitive employee information from unauthorized users.

Output:

- Role-based access to payroll system

- Secure authentication through identity provider
- Multi-Factor Authentication verification
- Monitoring and logging of administrator activities

Scenario 4: IT Helpdesk Remote Troubleshooting

In this scenario, the helpdesk engineer first authenticates using an identity provider like Microsoft Entra ID, Okta, or Active Directory. After successful authentication, Zscaler verifies the user identity and grants controlled access only to the required system or application for troubleshooting. Security mechanisms such as Multi-Factor Authentication (MFA) and role-based access control ensure that the IT staff can perform support tasks securely without exposing other sensitive resources in the organization's network.

Output:

- Secure authentication through Identity Provider
- Restricted access to specific systems for troubleshooting
- Multi-Factor Authentication verification
- Monitoring and logging of helpdesk activities

Scenario 5: Contractor Access to Project Management Tool

Since contractors are not permanent employees, their access must be carefully controlled to protect sensitive company data. In this scenario, the contractor authenticates through an identity provider such as Microsoft Entra ID, Okta, or Active Directory. After successful authentication, Zscaler verifies the user identity and applies access policies to ensure the contractor can only access the specific project management application required for their work. This approach helps organizations maintain secure collaboration with external users while protecting internal systems.

Output:

- Secure authentication for contractor through Identity Provider
- Limited access to project management tools
- Role-based access control for external users
- Monitoring and logging of contractor activities

Stage – 1

Title of the project:

Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Overview:

The Network Management (NM) project focuses on implementing a secure and efficient authentication system by integrating **Zscaler** with identity providers such as **Microsoft Entra ID**, **Okta**, and **Active Directory**. In modern organizations, employees and users often access applications and data from different locations and devices, which creates security challenges for IT administrators. Traditional security methods like VPN-based access provide broad network access after authentication, which can increase the risk of unauthorized activities.

This project demonstrates how identity-based security can improve protection by verifying user identity before granting access to applications or services. By integrating Zscaler with identity providers, users can securely log in through a centralized authentication system. Technologies such as Single Sign-On (SSO) and Multi-Factor Authentication (MFA) help ensure that only authorized users can access specific resources within the network.

The system also applies role-based access control, which means users are granted permissions based on their job roles, such as HR administrators, IT helpdesk staff, or contractors. Additionally, all access activities are monitored and logged to maintain transparency and improve security management. Overall, this project highlights how integrating cloud security platforms with identity providers helps organizations implement a Zero Trust security model, providing secure, scalable, and efficient access control for modern digital environments.

List of Vulnerability:

S.no	Category	Vulnerability Name	CWE/CVE - No
O1	Broken Access Control	Improper Access Control	284
02	Security Misconfiguration	Insufficient Session Expiration	613
03	Software Supply Chain Failures	Insecure Temporary File	377
04	Cryptographic Failures	Incorrect Default Permissions	276
05	Injection	Unverified Ownership	283
06	Insecure Design	Configuration	16
07	Authentication Failures	Weak Password requirments	521
08	Software or Data Integrity Failures	Improper Privilege Management	269
09	Security Logging and Alerting Failures	Insufficient Logging	778
10	Mishandling of Exceptional Conditions	Unimplemented or Unsupported Feature in UI	447

REPORT

1) Vulnerability Name: Insufficient Session Expiration

CWE/CVE: CWE-613

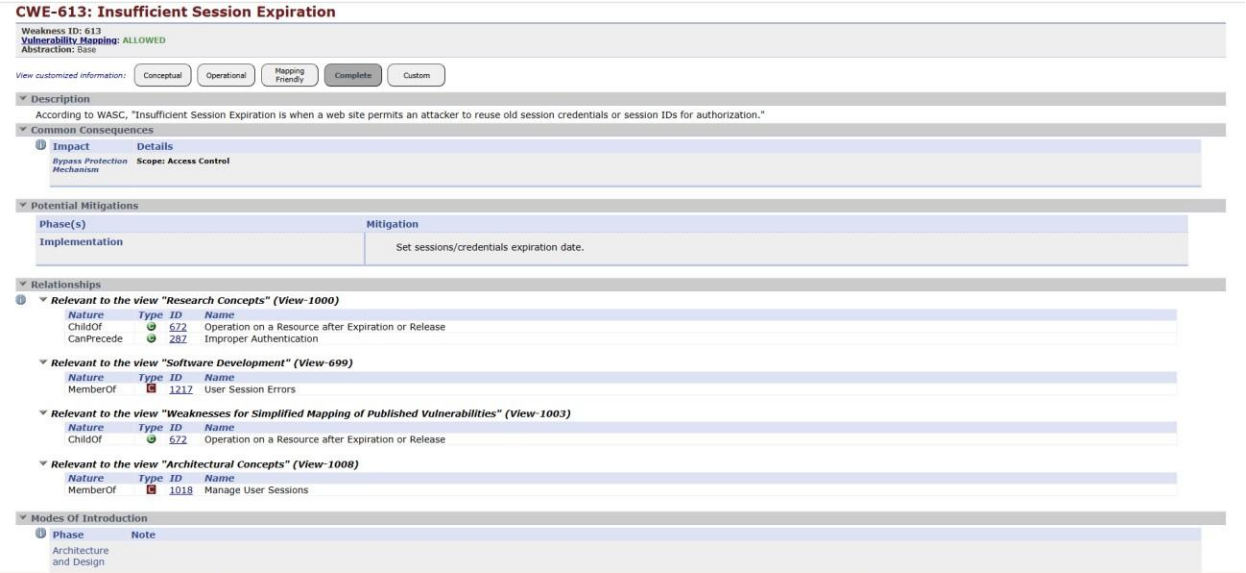
OWASP/SANS Category: A02:2025 – Security Misconfiguration

Description: Session tokens remain valid for a long time after user inactivity or logout. Attackers who obtain the session token can reuse it to gain unauthorized access.

Business Impact: Attackers may hijack user sessions and access protected resources.

Recommendation:

- Implement automatic session timeout.
- Invalidate session after logout.
- Use secure cookies and session management.



CWE-613: Insufficient Session Expiration

Weakness ID: 613
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

According to WASC, "Insufficient Session Expiration is when a web site permits an attacker to reuse old session credentials or session IDs for authorization."

Common Consequences

Impact	Details
Bypass Protection Mechanism	Scope: Access Control

Potential Mitigations

Phase(s)	Mitigation
Implementation	Set sessions/credentials expiration date.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf		672	Operation on a Resource after Expiration or Release
CanPrecede		287	Improper Authentication

Relevant to the view "Software Development" (View-699)

Nature	Type	ID	Name
MemberOf		1217	User Session Errors

Relevant to the view "Weaknesses for Simplified Mapping of Published Vulnerabilities" (View-1003)

Nature	Type	ID	Name
ChildOf		672	Operation on a Resource after Expiration or Release

Relevant to the view "Architectural Concepts" (View-1008)

Nature	Type	ID	Name
MemberOf		1018	Manage User Sessions

Modes Of Introduction

Phase	Note
Architecture and Design	

2) Vulnerability Name: Improper Access Control

CWE/CVE: CWE-284

OWASP/SANS Category: Broken Access Control

Description: Improper access control occurs when systems fail to correctly enforce restrictions on authenticated users. In identity-based systems, users may accidentally receive permissions beyond their job roles due to configuration errors or lack of role-based access policies. This can allow unauthorized viewing or modification of sensitive information.

Business Impact: Employees or attackers may gain access to confidential data, administrative functions, or restricted applications, which can compromise organizational security.

Recommendation:

- Implement Role-Based Access Control (RBAC).
- Define proper user roles and permissions.
- Regularly review access privileges.

CWE-284: Improper Access Control

Weakness ID: 284
Vulnerability Mapping: DISCOURAGED
Abstraction: Pillar

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Extended Description

Access control involves the use of several protection mechanisms such as:

- Authentication (proving the identity of an actor)
- Authorization (ensuring that a given actor can access a resource), and
- Accountability (tracking of activities that were performed)

When any mechanism is not applied or otherwise fails, attackers can compromise the security of the product by gaining privileges, reading sensitive information, executing commands, evading detection, etc.

There are two distinct behaviors that can introduce access control weaknesses:

- Specification: incorrect privileges, permissions, ownership, etc. are explicitly specified for either the user or the resource (for example, setting a password file to be world-writable, or giving administrator capabilities to a guest user). This action could be performed by the program or the administrator.
- Enforcement: the mechanism contains errors that prevent it from properly enforcing the specified access control requirements (e.g., allowing the user to specify their own privileges, or allowing a syntactically-incorrect ACL to produce insecure settings). This problem occurs within the program itself, in that it does not actually enforce the intended security policy that the administrator specifies.

Alternate Terms

Authorization	The terms "access control" and "authorization" are often used interchangeably, although many people have distinct definitions. The CWE usage of "access control" is intended as a general term for the various mechanisms that restrict which users can access which resources, and "authorization" is more narrowly defined. It is unlikely that there will be community consensus on the use of these terms.

Common Consequences

Impact	Details
Varies by Context	**Scope: Other**

3) Vulnerability Name: Unimplemented or Unsupported Feature in UI

CWE/CVE: CWE-447

OWASP/SANS Category: Mishandling of Exceptional Conditions

Description: This vulnerability occurs when a user interface provides options or features that are not fully implemented or supported by the system. Attackers may interact with these incomplete features to trigger unexpected behavior, bypass security controls, or exploit system errors.

Business Impact: Attackers may exploit unsupported features to cause system crashes, gain unauthorized access, or manipulate system operations.

Recommendation:

- Remove unused or incomplete UI features.
- Ensure all interface options are properly implemented and tested.
- Validate user actions before processing them in the system.

CWE-447: Unimplemented or Unsupported Feature in UI

Weakness ID: 447
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented.

Common Consequences

Impact	Details
Varies by Context; Unexpected State	**Scope: Other**

Potential Mitigations

Phase(s)	Mitigation
Testing	Perform functionality testing before deploying the application.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf		446	UI Discrepancy for Security Feature
ChildOf		671	Lack of Administrator Control over Security

Relevant to the view "Software Development" (View-699)

Nature	Type	ID	Name
MemberOf		355	User Interface Security Issues

Modes Of Introduction

Phase	Note
Implementation	

4) Vulnerability Name: Incorrect Default Permissions

CWE/CVE: CWE-276

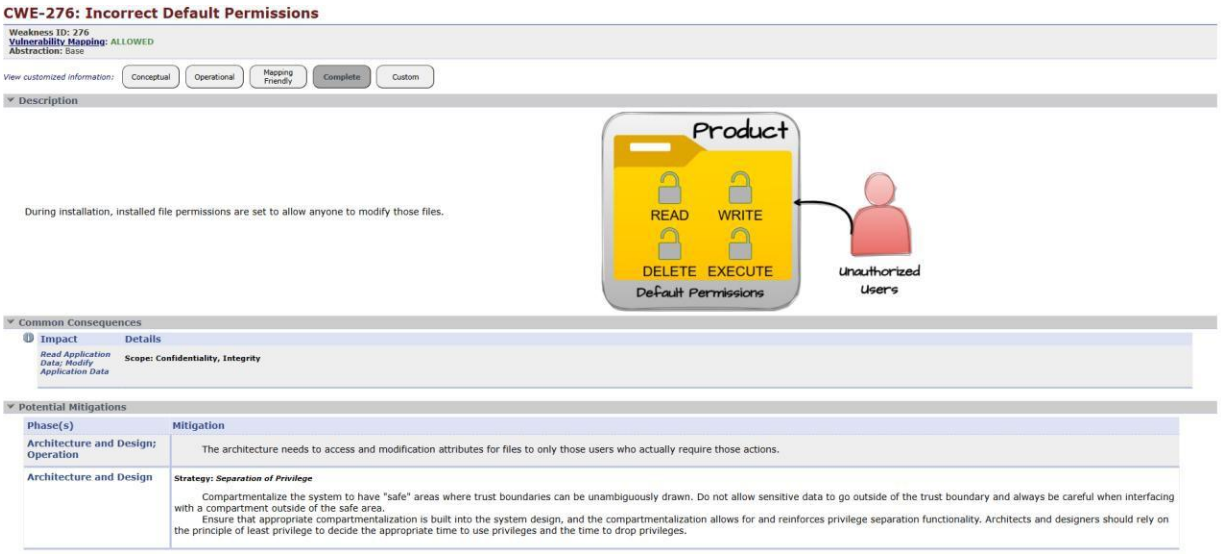
OWASP/SANS Category: A02:2025 – Security Misconfiguration

Description: This vulnerability occurs when files, directories, or system resources are created with overly permissive default access rights. If default permissions allow unauthorized users to read, modify, or execute files, attackers may exploit these permissions to gain access to sensitive information or modify system configurations.

Business Impact: Attackers may access confidential data, alter system files, or escalate privileges within the system, potentially leading to system compromise.

Recommendation:

- Configure secure default permissions for files and directories.
- Follow the principle of least privilege.
- Regularly audit and update access control permissions.



CWE-276: Incorrect Default Permissions

Weakness ID: 276
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

During installation, installed file permissions are set to allow anyone to modify those files.

Common Consequences

Impact	Details
Read Application Data; Modify Application Data	**Scope: Confidentiality, Integrity**

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design; Operation	The architecture needs to access and modification attributes for files to only those users who actually require those actions.
Architecture and Design	**Strategy:** ***Separation of Privilege*** Compartmentalize the system to have "safe" areas where trust boundaries can be unambiguously drawn. Do not allow sensitive data to go outside of the trust boundary and always be careful when interfacing with a compartment outside of the safe area. Ensure that appropriate compartmentalization is built into the system design, and the compartmentalization allows for and reinforces privilege separation functionality. Architects and designers should rely on the principle of least privilege to decide the appropriate time to use privileges and the time to drop privileges.

5) Vulnerability Name: Improper Privilege Management

CWE/CVE: CWE-269

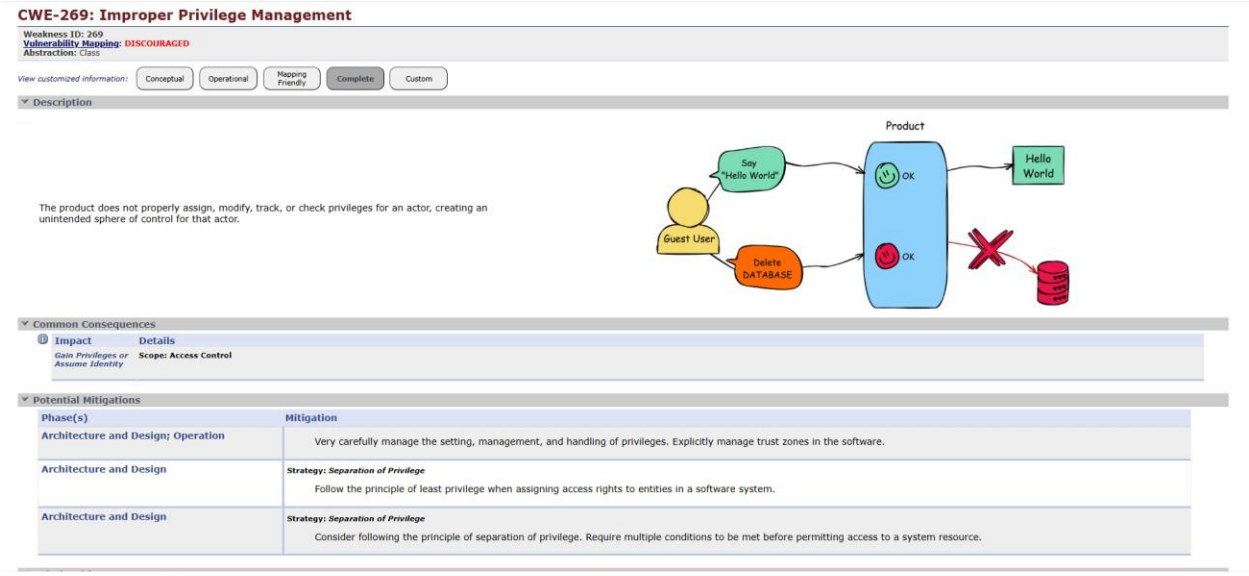
OWASP/SANS Category: Broken Access Control

Description: Improper Privilege Management occurs when a user gains higher access rights than originally granted. This vulnerability may occur due to improper access configuration or security flaws within authentication systems.

Business Impact: Attackers or internal users may gain administrative privileges, allowing them to modify system configurations, access sensitive data, or disrupt business operations.

Recommendation:

- Apply strict role-based permission policies.
- Monitor privilege changes.
- Restrict administrative access.



CWE-269: Improper Privilege Management

Weakness ID: 269
Vulnerability Mapping: DISCOURAGED
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product does not properly assign, modify, track, or check privileges for an actor, creating an unintended sphere of control for that actor.

Common Consequences

Impact	Details
Gain Privileges or Assume Identity	Scope: Access Control

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design; Operation	Very carefully manage the setting, management, and handling of privileges. Explicitly manage trust zones in the software.
Architecture and Design	Strategy: *Separation of Privilege* Follow the principle of least privilege when assigning access rights to entities in a software system.
Architecture and Design	Strategy: *Separation of Privilege* Consider following the principle of separation of privilege. Require multiple conditions to be met before permitting access to a system resource.

6) Vulnerability Name: Configuration

CWE/CVE: CWE-16

OWASP/SANS Category: Security Misconfiguration

Description: Configuration vulnerabilities occur when systems, applications, or security services are not properly configured. Incorrect settings, default credentials, or exposed services may allow attackers to gain unauthorized access to the system.

Business Impact: Improper configuration may lead to unauthorized access, exposure of sensitive data, or system compromise.

Recommendation:

- Apply secure configuration guidelines.
- Remove default credentials.
- Disable unnecessary services and ports.
- Perform regular security configuration audits..

CWE CATEGORY: Configuration

Category ID: 16
Vulnerability Mapping: PROHIBITED

Summary

Weaknesses in this category are typically introduced during the configuration of the software.

Membership

Nature	Type	ID	Name
MemberOf	V	635	Weaknesses Originally Used by NVD from 2008 to 2016
MemberOf	C	933	OWASP Top Ten 2013 Category A5 - Security Misconfiguration
MemberOf	C	1032	OWASP Top Ten 2017 Category A6 - Security Misconfiguration
MemberOf	C	1349	OWASP Top Ten 2021 Category A05:2021 - Security Misconfiguration
MemberOf	C	1437	OWASP Top Ten 2025 Category A02:2025 - Security Misconfiguration

Vulnerability Mapping Notes

Usage: PROHIBITED *(this CWE ID must not be used to map to real-world vulnerabilities)*

Reason: Category

Rationale:
This entry is a Category. Using categories for mapping has been discouraged since 2019. Categories are informal organizational groupings of weaknesses that can help CWE users with data aggregation, navigation, and browsing. However, they are not weaknesses in themselves [REF-1287]. This CWE entry may have become widely-used because of NIST's usage in NVD from 2008 to 2016 (see CWE-635 view, updated to the CWE-1003 view in 2016). Mapping is also Prohibited because this entry's status is Obsolete.

Comments:
As of CWE 4.9, "Configuration" is beginning to be treated as an aspect of the SDLC in which a product is directed (by a human or automated process) to perform an insecure behavior. CWE mapping should be conducted by analyzing the weakness in the behavior that has been set by the configuration, such as those related to access control (descendants of CWE-284) or resource management (CWE-400), etc.

Notes

Maintenance
Further discussion about this category was held over the CWE Research mailing list in early 2020. No definitive action has been decided.

Maintenance
This entry is a Category, but various sources map to it anyway, despite CWE guidance that Categories should not be mapped. In this case, there are no clear CWE Weaknesses that can be utilized. "Inappropriate Configuration" sounds more like a Weakness in CWE's style, but it still does not indicate actual behavior of the product. Further research is still required, however, as a "configuration weakness" might be Primary to many other CWEs, i.e., it might be better described in terms of chaining relationships.

7) Vulnerability Name: Insufficient Logging

CWE/CVE: CWE-778

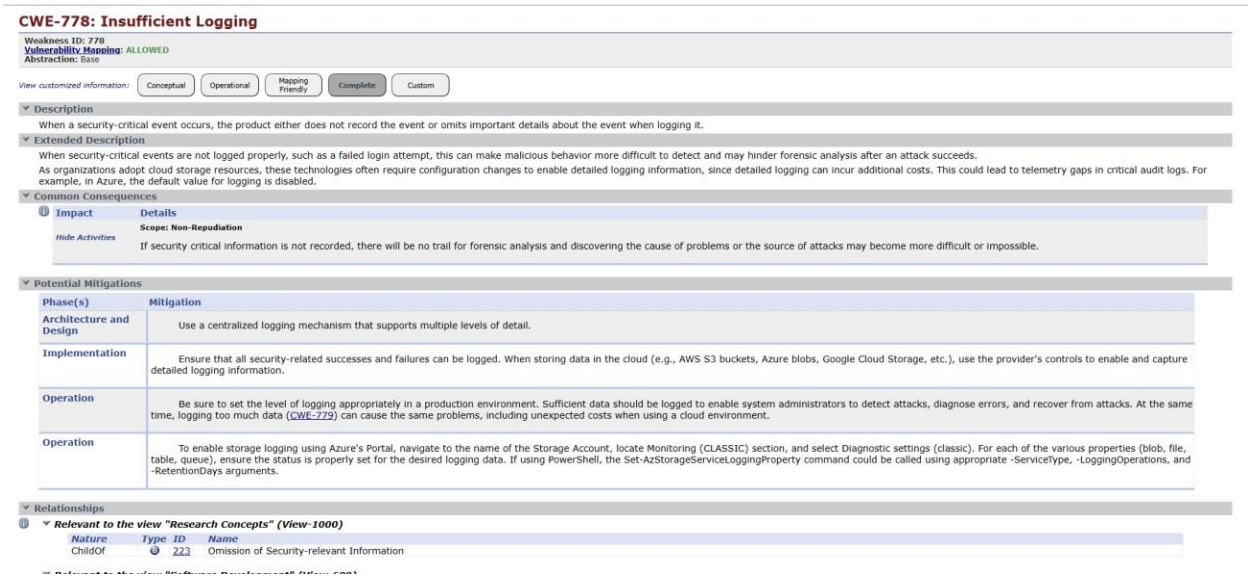
OWASP/SANS Category: Security Logging

Description: Systems that do not properly log authentication activities may fail to detect suspicious behavior such as repeated login failures, unusual login locations, or unauthorized access attempts. Without proper monitoring, attackers may remain undetected for long periods.

Business Impact: Delayed detection of cyber attacks can result in severe security incidents, data loss, and operational disruption.

Recommendation:

- Enable centralized logging systems.
- Monitor login activities.
- Set alerts for suspicious behavior.



CWE-778: Insufficient Logging

Weakness ID: 778
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

When a security-critical event occurs, the product either does not record the event or omits important details about the event when logging it.

Extended Description

When security-critical events are not logged properly, such as a failed login attempt, this can make malicious behavior more difficult to detect and may hinder forensic analysis after an attack succeeds.

As organizations adopt cloud storage resources, these technologies often require configuration changes to enable detailed logging information, since detailed logging can incur additional costs. This could lead to telemetry gaps in critical audit logs. For example, in Azure, the default value for logging is disabled.

Common Consequences

Impact	Details
Hide Activities	**Scope: Non-Repudiation** If security critical information is not recorded, there will be no trail for forensic analysis and discovering the cause of problems or the source of attacks may become more difficult or impossible.

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design	Use a centralized logging mechanism that supports multiple levels of detail.
Implementation	Ensure that all security-related successes and failures can be logged. When storing data in the cloud (e.g., AWS S3 buckets, Azure blobs, Google Cloud Storage, etc.), use the provider's controls to enable and capture detailed logging information.
Operation	Be sure to set the level of logging appropriately in a production environment. Sufficient data should be logged to enable system administrators to detect attacks, diagnose errors, and recover from attacks. At the same time, logging too much data (CWE-779) can cause the same problems, including unexpected costs when using a cloud environment.
Operation	To enable storage logging using Azure's Portal, navigate to the name of the Storage Account, locate Monitoring (CLASSIC) section, and select Diagnostic settings (classic). For each of the various properties (blob, file, table, queue), ensure the status is properly set for the desired logging data. If using PowerShell, the Set-AzStorageServiceLoggingProperty command could be called using appropriate -ServiceType, -LoggingOperations, and -RetentionDays arguments.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf		223	Omission of Security-relevant Information

8) Vulnerability Name: Unverified Ownership

CWE/CVE: CWE-283

OWASP/SANS Category: A01:2025 – Broken Access Control

Description: Unverified Ownership occurs when a system does not properly verify whether a user owns or is authorized to access a particular resource before allowing an operation. Attackers may manipulate object identifiers such as file IDs, user IDs, or resource references to access or modify data belonging to other users.

Business Impact: Unauthorized users may gain access to confidential information, modify data belonging to other users, or perform unauthorized actions in the system.

Recommendation:

- Verify resource ownership before granting access.
- Implement strong authorization checks.
- Apply Role-Based Access Control (RBAC).
- Validate user identity before processing requests.

CWE-283: Unverified Ownership

Weakness ID: 283
Vulnerability Mapping: ALLOWED
Abstraction: Base

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

The product does not properly verify that a critical resource is owned by the proper entity.

Common Consequences

Impact	Details
Gain Privileges or Assume Identity	**Scope: Access Control** An attacker could gain unauthorized access to system resources.

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design; Operation	Very carefully manage the setting, management, and handling of privileges. Explicitly manage trust zones in the software.
Architecture and Design	**Strategy:** ***Separation of Privilege*** Consider following the principle of separation of privilege. Require multiple conditions to be met before permitting access to a system resource.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf	C	282	Improper Ownership Management

Relevant to the view "Software Development" (View-699)

Nature	Type	ID	Name
MemberOf	C	840	Business Logic Errors

Relevant to the view "Architectural Concepts" (View-1008)

Nature	Type	ID	Name
MemberOf	C	1011	Authorize Actors

Modes Of Introduction

Phase	Note
Architecture and Design	REALIZATION: This weakness is caused during implementation of an architectural security tactic.

9) Vulnerability Name: Insecure Temporary File

CWE/CVE: CWE-377

OWASP/SANS Category:A02:2025 – Security Misconfiguration

Description: This vulnerability occurs when an application creates temporary files in an insecure manner. Temporary files may be stored in shared or publicly accessible directories with improper permissions. Attackers may access, modify, or replace these files to obtain sensitive information or interfere with application processes.

Business Impact: Sensitive data stored in temporary files may be exposed to unauthorized users. Attackers may also manipulate temporary files to alter system behavior or gain unauthorized access.

Recommendation:

- Store temporary files in secure directories.
- Apply strict file permission controls.
- Delete temporary files immediately after use.

CWE-377: Insecure Temporary File

Weakness ID: 377
Vulnerability Mapping: ALLOWED **(with careful review of mapping notes)**
Abstraction: Class

View customized information: Conceptual | Operational | Mapping Friendly | Complete | Custom

Description

Creating and using insecure temporary files can leave application and system data vulnerable to attack.

Common Consequences

Impact	Details
Read Files or Directories; Modify Files or Directories	**Scope: Confidentiality, Integrity**

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf	C	668	Exposure of Resource to Wrong Sphere
ParentOf	B	378	Creation of Temporary File With Insecure Permissions
ParentOf	B	379	Creation of Temporary File in Directory with Insecure Permissions

Modes Of Introduction

Phase	Note
Implementation	

Applicable Platforms

Languages	Class: Not Language-Specific *(Undetermined Prevalence)*

Demonstrative Examples

Example 1

The following code uses a temporary file for storing intermediate data gathered from the network before it is processed.

Example Language: C (bad code)

```
if (tmpnam_r(filename)) {

  FILE* tmp = fopen(filename,"wb+");
  while((recv(sock,recvbuf,DATA_SIZE, 0) > 0)&(amt!=0)) amt = fwrite(recvbuf,1,DATA_SIZE,tmp);
}
...
```

10) Vulnerability Name: Weak Password requirments

CWE/CVE: CWE-521

OWASP/SANS Category: A07 Authentication Failures

Description: Weak password requirements allow users to create simple or easily guessable passwords. Without strong password requirements such as minimum length, special characters, and periodic updates, attackers can perform brute-force or dictionary attacks to compromise accounts.

Business Impact: Compromised user accounts can lead to unauthorized system access, data leakage, and potential security breaches.

Recommendation:

- Enforce strong password policies.
- Require minimum password length and complexity.
- Implement periodic password changes.

CWE-521: Weak Password Requirements

WNkftesslO;Sll
□ ,ALtowro
A!Ktndlooo:8-

,,D,eso1plloo

The product does not require that users should have strong passwords.

- Common Con□uencH
  - 0 Imp;,e;t Oef,1il,c
    — □ 1 ◇ . Sc.....Accu•c-,...,
    "'. IdHJtr Anattacke, could easdy guess us« passwords and o,at1 access user acc::ouots.

'''Potentl,1 □

Ptlase(s) MltlgiltIon

Architecture and ''''''

Aproduct's designshouldreqlIlre adherance to an appropriate passVI'OrdpollC'f. Speatk passwOfd requirements depend strongly on contextual flKtOfs, OOt It 1s recommended to contain the folowIng attnbutes:

EnfOfCll',□nt o/ a minimum andmaximum M"ngth
Restncuons □Instpassword reuse
RutrictionS 9inst USIngawrmonpasswords
RestrktIOOS against OSIngcontelrtUal stringIn thepassword(e.g., us« 1..:1, app na□)

Depending on the threat model. the password policy may ind□.seventl additional 11ttr1butes.

- COmplex□word5 requirinl,I mixeddl?Kter 5etS (•lpha, numenc, 5P«i•, mixed aise)
  - o 1increas1ng the ranoe o/ dlaractt-rs makMthe passWOfd hardt-r to aackandmay bt app<op,lM:11',for 1ysttms rel□ngon □...factor.authentIltIltIOn
    Unfortu□tely, a complexpassword may be dIfflo..llt to memorize, encour.glng a Usel" to select a 5hort password or to InCOrTectty □ the □ (wnte It down).
  - o AnOther disadvantage o/ thIs a,pproadTIs that ii oftendoes not result in a SignifIant increases in over• passwordcomplexity due to peop1e s predlCt□usaped vatIOus symbols.
- Large Minimum□ (encouraging passpt,rases IOStead o/ passwords)
  - o IncreMtngthe numbei-'of d'laractenmlIkes the passwO('d hM<ler to a.ck andmay be •pp-opnate fOf systlIfm rety,ng on Mogle factO('11ulhenticat1on.
  - o A diudvantq o/lhis appr-Neh Is thM: selecting• good p,,sspti...se:Is not easy and poor I)MSWOI'ds cw! stil begenerated. SOtne prompting may be□ to encot#'• longun-predictable passwords.
- Randomly Chosen secrets
  - ii Gener.111ng a PIlSSWOfdfOf the user can helpmal,,e sure th□ length andcomptextty req1.11rementsare met, andcan r□ m secure passwords betogused.
    Adiudvantage o/ lhlsapprNCh II U\M:tM rHUltIng p,,ssword or p,assphatse may be too diMcult to □mor1ze, fflCOI.QgIng thNn to beWf!ttt,n down.

SeeNIST 800-638 (.REf.1.Ilil] ,□ furthel'information on passwOl'd requirements.

Stage – 2

Title of the project:

Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Overview:

Nessus is a popular vulnerability assessment tool developed by **Tenable**. It is used by security professionals to identify weaknesses in computer systems, servers, and web applications.

Nessus performs **remote vulnerability scanning**, meaning it does not need to be installed on the target machine. Instead, it sends various network requests to the target host and analyzes the responses to detect potential security vulnerabilities.

The tool works using a **plugin-based architecture**, where each plugin is designed to check for a specific type of vulnerability such as outdated software, insecure configurations, weak encryption protocols, or exposed services. Nessus maintains a large plugin database that allows it to detect thousands of known security issues.

During a scan, Nessus first performs **host discovery** to identify the target system and gather basic information such as operating system details and running services. After collecting this information, the scanner performs multiple vulnerability tests to determine whether the system contains any known security weaknesses.

Once the scanning process is completed, Nessus generates a **comprehensive vulnerability report** that includes severity levels, descriptions of vulnerabilities, and recommended remediation steps.

SCANNING CAPABILITIES

Nessus can scan a wide range of targets including:

- Individual computers and servers
- Entire network infrastructures
- Web applications and services
- Specific ports and running services

Scans can be performed **manually** or **scheduled automatically**, allowing continuous monitoring of system security.

WORKING PROCESS OF NESSUS

The vulnerability scanning process using Nessus involves the following steps:

1. Connection Establishment
Nessus establishes communication with the target host using protocols such as TCP, UDP, and ICMP.

2. System Discovery
The scanner identifies the operating system, open ports, and services running on the target machine.

3. Vulnerability Analysis
Nessus runs multiple security plugins to check for known vulnerabilities and misconfigurations.

4. Report Generation
After the analysis, Nessus generates a detailed report that shows vulnerability severity, description, and recommended solutions.

ADVANTAGES OF USING NESSUS

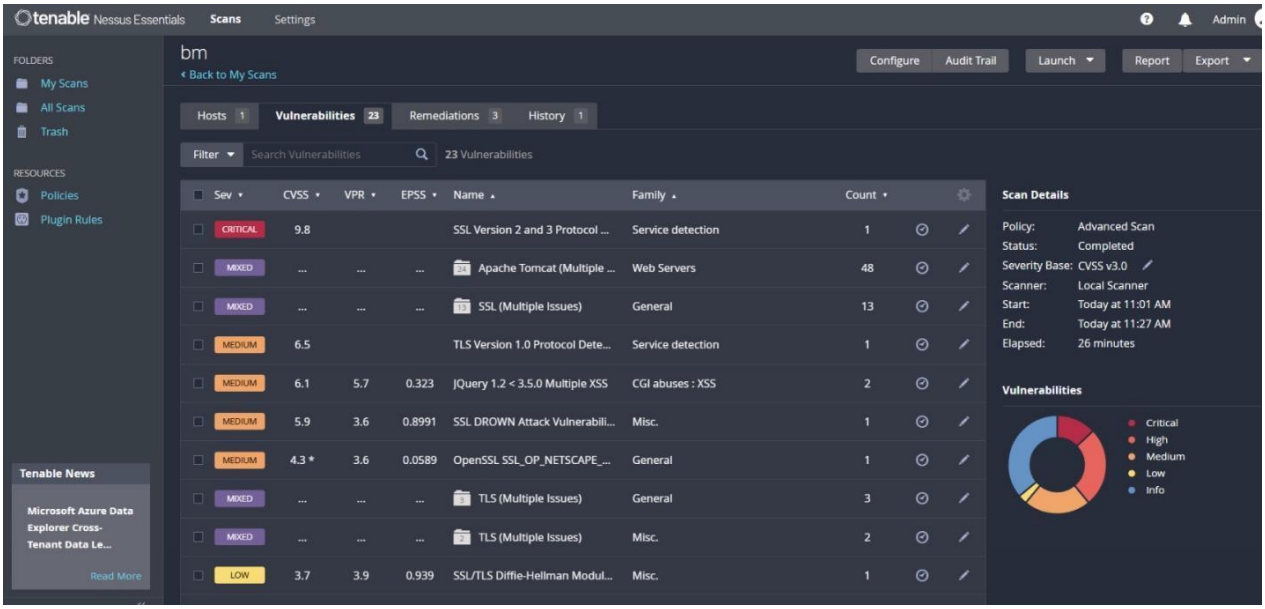
- **Large vulnerability database** capable of detecting thousands of security flaws.
- **User-friendly interface** that simplifies scan configuration and report analysis.
- **Detailed security reports** including severity levels and remediation steps.
- **Scalable scanning capability** for single hosts, networks, or web applications.
- **Flexible scan scheduling** allowing both manual and automated scans.

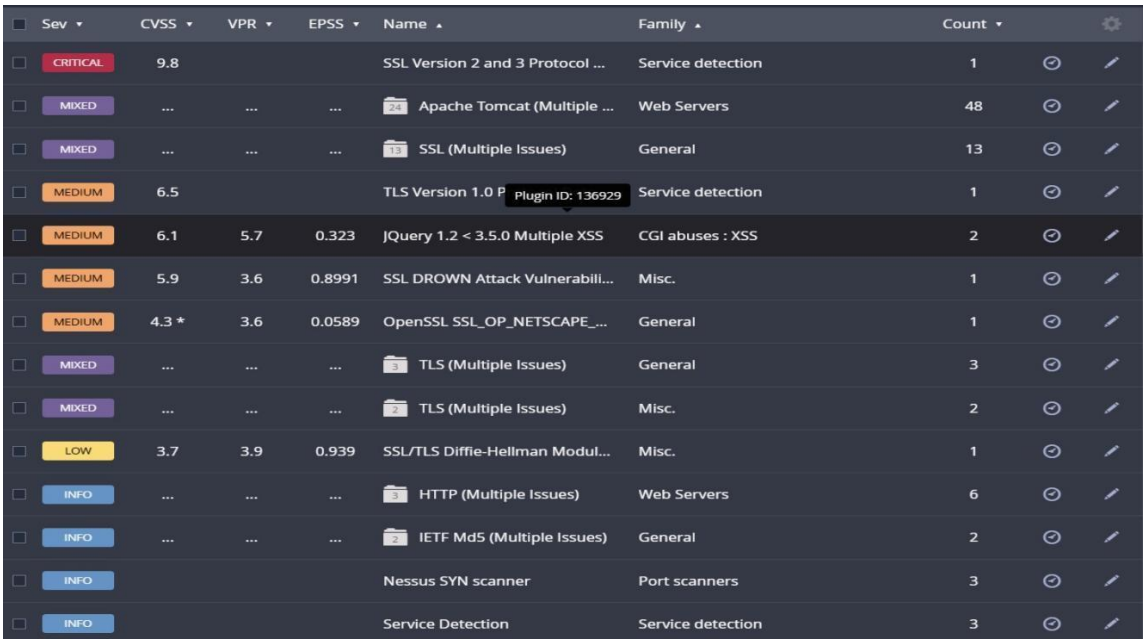
TARGET DETAILS

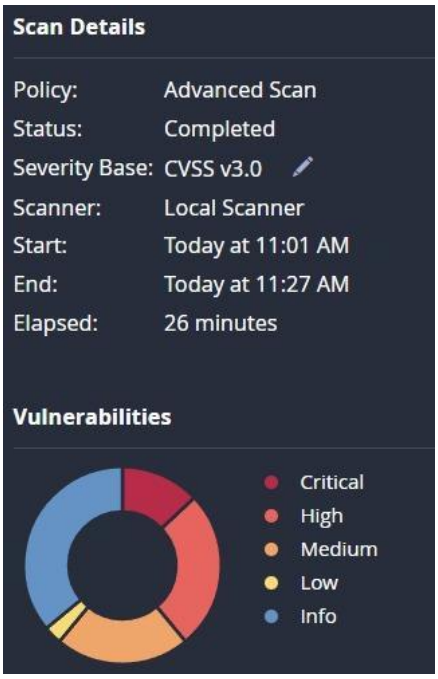
Target Website:
http://zero.webappsecurity.com

Target IP Address:
54.82.22.214

NESSUS SCAN REPORT :


tenable Nessus Essentials
Scans
Settings
Admin
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
Microsoft Azure Data Explorer Cross-Tenant Data Le...
Read More
bm
Back to My Scans
Configure
Audit Trail
Launch
Report
Export
Hosts 1
Vulnerabilities 23
Remediations 3
History 1
Filter
Search Vulnerabilities
23 Vulnerabilities
Sev
CVSS
VPR
EPSS
Name
Family
Count
CRITICAL 9.8 SSL Version 2 and 3 Protocol ... Service detection 1
MIXED ... ... Apache Tomcat (Multiple ... Web Servers 48
MIXED ... ... SSL (Multiple Issues) General 13
MEDIUM 6.5 TLS Version 1.0 Protocol Dete... Service detection 1
MEDIUM 6.1 5.7 0.323 jQuery 1.2 < 3.5.0 Multiple XSS CGI abuses : XSS 2
MEDIUM 5.9 3.6 0.8991 SSL DROWN Attack Vulnerabili... Misc. 1
MEDIUM 4.3 * 3.6 0.0589 OpenSSL SSL_OP_NETSCAPE_... General 1
MIXED ... ... TLS (Multiple Issues) General 3
MIXED ... ... TLS (Multiple Issues) Misc. 2
LOW 3.7 3.9 0.939 SSL/TLS Diffie-Hellman Modul... Misc. 1
Scan Details
Policy: Advanced Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 11:01 AM
End: Today at 11:27 AM
Elapsed: 26 minutes
Vulnerabilities
Critical
High
Medium
Low
Info


Sev
CVSS
VPR
EPSS
Name
Family
Count
CRITICAL 9.8 SSL Version 2 and 3 Protocol ... Service detection 1
MIXED ... ... Apache Tomcat (Multiple ... Web Servers 48
MIXED ... ... SSL (Multiple Issues) General 13
MEDIUM 6.5 TLS Version 1.0 P Plugin ID: 136929 Service detection 1
MEDIUM 6.1 5.7 0.323 jQuery 1.2 < 3.5.0 Multiple XSS CGI abuses : XSS 2
MEDIUM 5.9 3.6 0.8991 SSL DROWN Attack Vulnerabili... Misc. 1
MEDIUM 4.3 * 3.6 0.0589 OpenSSL SSL_OP_NETSCAPE_... General 1
MIXED ... ... TLS (Multiple Issues) General 3
MIXED ... ... TLS (Multiple Issues) Misc. 2
LOW 3.7 3.9 0.939 SSL/TLS Diffie-Hellman Modul... Misc. 1
INFO ... ... HTTP (Multiple Issues) Web Servers 6
INFO ... ... IETF Md5 (Multiple Issues) General 2
INFO Nessus SYN scanner Port scanners 3
INFO Service Detection Service detection 3



List of Vulnerability :

S.no	Vulnerability Name	Severity	Plugins ID
1	Nessus SYN Scanner	Info	11219
2	Service Detection	Info	22964
3	jQuery Detection	Info	106658
4	Aditional DNS Hostnames	Info	46180
5	Nessus scan information	Info	19506
6	OS Fingerprints Detected	Info	209654
7	Patch Report	Info	66334
8	Traceroute information	Info	10287

1. NESSUS SYN SCANNER

Vulnerability Name:
Nessus SYN Scanner

Severity:
Info

Plugin:
11219

Port:
Multiple Ports

Description:
The SYN scanner is used to detect open ports on the target system. It sends SYN packets to the target host and analyzes responses to identify active services. This technique is commonly used during vulnerability assessment to gather information about exposed services.

Solution:
Configure firewalls and intrusion detection systems (IDS) to monitor and restrict unauthorized port scanning activities. Network administrators should ensure that only necessary ports are open.

Business Impact:
Attackers may use port scanning techniques to discover open services and identify potential attack points within the system.

INFO Nessus SYN scanner

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Output

```
Port 80/tcp was found to be open
```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	54.82.22.214

```
Port 443/tcp was found to be open
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp	54.82.22.214

2. Service Detection

Vulnerability Name:
Service Detection

Severity:
Info

Plugin:
22964

Port:
Multiple Ports

Description:
This plugin detects services running on open ports of the target system. Identifying services helps security professionals understand what applications are exposed to the network.

Solution:
Disable unnecessary services and ensure that required services are properly configured and regularly updated with security patches.

Business Impact:
Exposure of unnecessary services increases the attack surface and may allow attackers to exploit vulnerabilities in outdated services.

INFO Service Detection

Description

Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

Output

```
A web server is running on this port.
```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	54.82.22.214
8080 / tcp / www	54.82.22.214

```
A TLSv1 server answered on this port.
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp	54.82.22.214

3. JQUERY DETECTION

Vulnerability Name:
jQuery Detection

Severity:
Info

Plugin:
106658

Port:
80 / 443

Description:
The scanner detected the presence of the jQuery JavaScript library on the web application. Older versions of jQuery may contain security vulnerabilities that attackers could exploit.

Solution:
Update the jQuery library to the latest secure version and regularly monitor for security updates.

Business Impact:
Outdated JavaScript libraries may expose the application to client-side attacks such as Cross-Site Scripting (XSS).

INFO JQuery Detection

Description

Nessus was able to detect JQuery on the remote host.

See Also

https://jquery.com/

Output

```
URL     : http://54.82.22.214/resources/js/jquery-1.8.2.min.js
Version : 1.8.2
```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	54.82.22.214

```
URL     : http://54.82.22.214:8080/resources/js/jquery-1.8.2.min.js
Version : 1.8.2
```

To see debug logs, please visit individual host

Port	Hosts
8080 / tcp / www	54.82.22.214

4. ADDITIONAL DNS HOSTNAMES

Vulnerability Name:
Additional DNS Hostnames

Severity:
Info

Plugin:
46180

Port:
53

Description:
The scan identified additional DNS hostnames associated with the target system. These hostnames may reveal additional infrastructure details.

Solution:
Review DNS configurations and remove unnecessary or unused hostnames to reduce information disclosure.

Business Impact:
Attackers may use DNS information to map network infrastructure and identify additional targets.

INFO Additional DNS Hostnames

Description

Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for vhosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution

If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com[192.0.32.10]

See Also

https://en.wikipedia.org/wiki/Virtual_hosting

Output

```
The following hostnames point to the remote host :
  - zero.webappsecurity.com
```

To see debug logs, please visit individual host

Port	Hosts
N/A	54.82.22.214

5. Nessus Scan Information

Vulnerability Name:
Nessus Scan Information

Severity:
Info

Plugin:
19506

Port:
N/A

Description:
This plugin provides general information about the scan, including the scan start time, scanner version, and scanning configuration.

Solution:
No action is required. This plugin is informational and used for documentation purposes.

Business Impact:
There is no direct security impact as this entry only provides scan-related details.

INFO Nessus Scan Information

Description

This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

Output

```
Information about this scan :

Nessus version : 10.11.3
Nessus build : 20047
Plugin feed version : 202602132103
Scanner edition used : Nessus Home

ERROR: Your plugins have not been updated since 2026/2/13
Performing a scan with an older plugin set will yield out-of-date results and
more...
```

To see debug logs, please visit individual host

6. OS Fingerprints Detected

Vulnerability Name:
Operating System Fingerprinting

Severity:
Info

Plugin:
209654

Port:
Multiple Ports

Description:
The scanner identified the operating system running on the target host by analyzing network responses. OS fingerprinting helps identify system characteristics.

Solution:
Implement network security controls such as firewalls and intrusion prevention systems to limit system fingerprinting attempts.

Business Impact:
Attackers may use OS information to launch targeted attacks against known vulnerabilities of that operating system.

Hosts 1 | **Vulnerabilities** 27 | Remediations 3 | Notes 1 | History 1

INFO OS Fingerprints Detected

Description

Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. While the highest-confidence result was reported in plugin 11936, "OS Identification", the complete set of fingerprints detected are reported here.

Output

```
Following OS Fingerprints were found

Remote operating system : Apple TV (3rd Generation)
Confidence level : 56
Method : MLSinFP
Type : unknown
Fingerprint : unknown

Remote operating system : Microsoft Windows Vista
more...
```

To see debug logs, please visit individual host

Port	Hosts
N/A	54.82.22.214

7. PATCH REPORT

Vulnerability Name:
Patch Report

Severity:
Info

Plugin:
66334

Port:
N/A

Description:
This report provides information about missing or installed security patches on the system.

Solution:
Ensure all operating systems and applications are updated regularly with the latest security patches.

Business Impact:
Unpatched systems may contain vulnerabilities that attackers can exploit to compromise the system.

INFO Patch Report

Description

The remote host is missing one or more security patches. This plugin lists the newest version of each patch to install to make sure the remote host is up-to-date.

Note: Because the 'Show missing patches that have been superseded' setting in your scan policy depends on this plugin, it will always run and cannot be disabled.

Solution

Install the patches listed below.

Output

```
. You need to take the following 3 actions :

[ Apache Tomcat 7.0.0 < 7.0.108 multiple vulnerabilities (147163) ]

+ Action to take : Upgrade to Apache Tomcat version 7.0.108 or later.

+Impact : Taking this action will resolve 32 different vulnerabilities (CVEs).
more...
```

To see debug logs, please visit individual host

Port	Hosts
N/A	54.82.22.214

8. Traceroute Information

Vulnerability Name:
Traceroute Information

Severity:
Info

Plugin:
10287

Port:
N/A

Description:
Traceroute information identifies the network path between the scanner and the target host. It helps analyze network routing and connectivity.

Solution:
Restrict ICMP responses and configure network security devices to limit exposure of network routing details.

Business Impact:
Attackers may use traceroute results to map the network infrastructure and identify potential attack paths.

INFO Traceroute Information

Description

Makes a traceroute to the remote host.

Output

```
For your information, here is the traceroute from 10.254.43.87 to 54.82.22.214 :
10.254.43.87
10.254.43.91
192.0.0.1
?
54.82.22.214
?
54.82.22.214

Hop Count: 8
```

To see debug logs, please visit individual host

Port	Hosts
0 / udp	54.82.22.214

Stage – 3

Title of the project:

Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

SOC (Security Operations Center)

A Security Operations Center (SOC) is a centralized unit responsible for monitoring, detecting, analyzing, and responding to cybersecurity threats within an organization. In the context of our project, SOC plays a vital role in monitoring authentication events and access activities when Zscaler is integrated with Identity Providers such as Azure AD, Okta, and Active Directory. SOC analysts continuously observe logs generated by Zscaler and identity platforms to detect suspicious login attempts, unauthorized access, or abnormal user behavior. By using SOC monitoring, organizations can ensure that only authenticated and authorized users access secure applications through Zscaler, strengthening the Zero Trust security architecture.

SOC Cycle

The SOC cycle describes the continuous process used by SOC teams to maintain organizational security. The cycle includes several steps such as monitoring, detection, investigation, response, and improvement. In our project, SOC first monitors authentication logs from Zscaler and Identity Providers. When suspicious activity is detected, such as multiple failed login attempts or access from unusual locations, SOC analysts investigate the event. If the activity is confirmed as malicious, incident response procedures are triggered to block the user or device. Finally, SOC teams review the incident and update security policies to prevent similar attacks in the future.

SIEM (Security Information and Event Management)

SIEM is a security solution that collects, analyzes, and correlates security logs from multiple sources across the organization. In our project, SIEM collects logs from Zscaler, Azure AD, Okta, and Active Directory. These logs include user authentication attempts, access requests, system alerts, and network activity. SIEM tools help security teams identify suspicious patterns such as unauthorized login attempts, abnormal access times, or multiple authentication failures. By centralizing security logs, SIEM helps organizations detect threats quickly and respond before any serious damage occurs.

SIEM Cycle

The SIEM cycle involves collecting security data, analyzing events, detecting threats, responding to incidents, and improving security policies. First, logs from Zscaler and Identity Providers are collected into the SIEM platform. Next, the system analyzes the logs using correlation rules and threat intelligence. If suspicious behavior is detected, SIEM generates alerts for SOC analysts. After investigation, security teams take appropriate actions such as blocking users or updating security configurations. The final step is improving the detection rules to prevent similar threats in the future.

MISP (Malware Information Sharing Platform)

MISP is an open-source threat intelligence platform used for sharing cyber threat information between organizations. It allows security teams to collect, store, and share information about malware, attack techniques, and suspicious IP addresses. In our project environment, MISP can be integrated with SIEM to provide threat intelligence data related to malicious login attempts or compromised accounts. By using MISP, SOC teams can quickly identify known attack patterns and improve the detection capabilities of the security monitoring system.

Your College Network Information

In our college network environment, multiple systems are connected such as student portals, faculty systems, administrative applications, and internal servers. These systems must be protected from unauthorized access. By integrating Zscaler with Identity Providers such as Azure AD, Okta, and Active Directory, the college network can ensure that all users authenticate using centralized identity services. This allows secure access to applications while maintaining strict authentication and authorization controls.

How SOC Can Be Deployed in Our College

To deploy SOC in our college, security monitoring tools such as SIEM can be implemented to collect logs from network devices, servers, and identity platforms. The SOC team would monitor authentication logs, system activities, and security alerts generated by Zscaler and other systems. If a suspicious login or unusual access attempt is detected, SOC analysts can quickly investigate and respond to the threat. This helps protect student data, faculty information, and sensitive institutional resources from cyber attacks.

Threat Intelligence

Threat intelligence refers to information about potential cyber threats that can help organizations detect and prevent attacks. It includes details about malicious IP addresses, malware signatures, attack patterns, and hacker techniques. In our project, threat intelligence can be integrated with SIEM systems to improve detection of suspicious authentication activities. By using threat intelligence, SOC teams can identify known attack sources and block them before they compromise the network.

Incident Response

Incident response is the process used by security teams to handle cybersecurity incidents effectively. When a security alert is triggered by the SIEM system, SOC analysts analyze the event to determine whether it is a real threat. If a malicious activity is confirmed, actions such as blocking the user account, terminating the session, or restricting network access can be performed. In our project scenario, incident response helps prevent unauthorized users from accessing protected applications through Zscaler.

QRadar and Understanding the Tool

IBM QRadar is a popular SIEM tool used for security monitoring and threat detection. QRadar collects logs from multiple sources such as network devices, servers, applications, and identity providers. It analyzes the collected data using correlation rules to identify suspicious activities. In the context of our project, QRadar can collect authentication logs from Zscaler and identity platforms like Azure AD and Okta. This helps security teams identify threats such as brute-force login attempts, unauthorized access attempts, and suspicious user behavior.

Conclusion

Stage-1: In Stage 1, we understood the importance of web application security testing using OWASP Top 10 vulnerabilities. Identifying vulnerabilities such as XSS, TLS misconfiguration, and improper access control helps protect web applications from cyber attacks.

Stage-2: In Stage 2, we used the Nessus vulnerability scanner to identify security weaknesses in a target system. The Nessus report provided details about vulnerabilities such as outdated TLS protocols and server misconfigurations.

Stage-3: In Stage 3, we learned about SOC, SIEM, and QRadar dashboards used for monitoring security events. These technologies help organizations detect

threats, monitor authentication activities, and respond quickly to security incidents.

Future Scope

Stage-1: Future web application testing will involve advanced automated security tools and AI-based vulnerability detection methods.

Stage-2: Vulnerability scanning tools like Nessus will continue to evolve with more advanced detection techniques and automated remediation capabilities.

Stage-3: SOC and SIEM platforms will integrate AI-based threat detection and automated response systems to improve cybersecurity defense mechanisms.

Topics Explored

- Web Application Security
- Vulnerability Assessment
- Security Monitoring
- Identity and Access Management
- SOC and SIEM Architecture

Tools Explored

- Nessus Vulnerability Scanner
- Zscaler Security Platform
- IBM QRadar SIEM
- Security Headers
- OpenSSL

The End